

Basic SSRF against the local server

Topic: SSRF | Difficulty: Apprentice

Description

The stock check feature accepts a user-controlled URL via the 'stockApi' parameter and makes a server-side HTTP request to it. By substituting a URL pointing to localhost the attacker can access the application's internal admin interface which is only accessible from the server itself, bypassing all network-level controls.

Steps to Exploit

1. Navigate to a product page and click 'Check stock'.
2. Intercept the POST request to /product/stock in Burp Suite.
3. Locate the 'stockApi' parameter containing the original stock check URL.
4. Replace the URL value with: `http://localhost/admin`
5. Forward the request and observe the admin panel HTML returned in the response body.
6. Send a further SSRF request to: `http://localhost/admin/delete?username=carlos`

Proof of Concept

Original stockApi:

```
https://stock.weliketoshop.net/product/stock/check?productId=1&storeId=1
```

SSRF payload:

```
stockApi=http://localhost/admin
```

Delete user:

```
stockApi=http://localhost/admin/delete?username=carlos
```

Impact

- Access to admin interface bypassing authentication (server requests are trusted).
- Ability to delete any user account from the internal admin panel.
- Access to any internal service reachable from the application server.
- Complete bypass of all network-level access controls and firewall rules.

Mitigation / Remediation

1. Validate user-supplied URLs against a strict allowlist of permitted external hosts.
2. Block outbound requests to loopback addresses (127.0.0.1, localhost) and internal IPs.
3. Do not grant elevated trust to requests originating from localhost; enforce authentication.
4. Implement network-level egress filtering on the application server.

CVSS Score

CVSS v3.1: 9.8 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Justification

- Attack Vector: Network - HTTP parameter manipulation.
- Attack Complexity: Low - single URL substitution.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality / Integrity / Availability: High - full admin access and user deletion.